# PCA / PRA — Plateforme de paiement RESILIENCE-ALPHA

> ***Statut : cible.*** *Ce document décrit ce que l'équipe vise et a décidé, pas ce qui est déjà codé. L'état réel du code est suivi dans `constat/etat-implementation.md`.*

> *Ticket : WOR-71 · Responsable : Cédric · Version 0.1 du 19/10/2026*
>
> *Ce plan s'appuie sur la matrice de risques (`ebios-rm.md`), le coût d'un arrêt (`services-critiques.md`), les objectifs de reprise (`rto-rpo.md`) et l'analyse réglementaire (`nis2-dora.md`).*
>
> ***Statut :*** *les mécanismes décrits sont ceux **prévus** pour le démonstrateur. Au 20/10, le moteur de remédiation, le modèle de détection et les sauvegardes ne sont pas encore codés : voir `constat/etat-implementation.md`. Chaque fiche sera confirmée ou corrigée après les essais de restauration (WOR-75), le chaos engineering (WOR-76) et les répétitions (WOR-78).*
>
> *Ce document est indexé par l'assistant RAG (WOR-56). Chaque fiche scénario est donc rédigée pour être lue seule.*

## 1. Objet et périmètre

- **PCA (plan de continuité)** : comment le service de paiement **continue** pendant l'incident, en mode normal ou dégradé.
- **PRA (plan de reprise)** : comment on **revient** à un état sain et vérifié après l'incident, avec quelles données.

| Dans le périmètre | Hors périmètre |
|---|---|
| Plateforme Docker Compose du PC Hôte : front, authentification, API de paiement, base de données, WAF, supervision, détection ML, moteur de remédiation, assistant RAG | Infrastructure du campus, postes des autres groupes |
| Incidents de disponibilité, d'intégrité, défaillances internes, perte de l'hôte | Données réelles : toutes les données sont fictives |

## 2. Rôles et responsabilités

### 2.1 Dans l'entreprise fictive

| Rôle | Responsabilité pendant un incident |
|---|---|
| **Moteur de remédiation (automate)** | Premier intervenant : détecte, décide, agit et vérifie dans le périmètre d'actions qui lui est autorisé |
| **Opérateur d'astreinte** (équipe production) | Surveille le tableau de bord, reprend la main si l'automate échoue ou sort de son périmètre |
| **Responsable de la production** | Décide des restaurations de données et des modes dégradés |
| **RSSI** | Qualifie les incidents de sécurité, décide de la préservation des preuves et de la rotation des secrets |
| **Directeur de crise** (direction des opérations) | Pilote la cellule de crise, arbitre entre reprise rapide et investigation |
| **Conformité** | Classe l'incident selon DORA et prépare les notifications à l'ACPR |
| **Communication** | Informe les partenaires commerçants |
| **DPO** | Évalue l'atteinte aux données personnelles (RGPD) |

### 2.2 Dans l'équipe du démonstrateur

| Membre | Ce qu'il porte dans ce plan |
|---|---|
| Michael (Développement) | Moteur de remédiation, vérification de la reprise, cohérence des données |
| Reza (Infrastructure) | Playbooks Ansible, sauvegardes et restauration, remise à l'état sain |
| Léa (IA / Data) | Détection ML, assistant RAG |
| Axel (Cybersécurité) | WAF, SIEM, secrets, préservation des journaux |
| Cédric (Gouvernance) | Ce plan, classification des incidents, notifications, retour d'expérience |

## 3. Niveaux de réponse et escalade

Les seuils viennent du coût d'un arrêt (`services-critiques.md`).

| Niveau | Déclencheur | Qui agit | Gravité |
|---|---|---|---|
| **N0 — Automatique** | Alerte ML ou SIEM | Moteur de remédiation seul ; l'opérateur est informé | G1 |
| **N1 — Astreinte** | Échec de la remédiation, **ou** service non rétabli à 5 min, **ou** incident d'intégrité ou de confidentialité (même si la remédiation a réussi) | Opérateur d'astreinte, RSSI informé | G2 |
| **N2 — Cellule de crise** | Service non rétabli à 30 min, **ou** perte de données confirmée, **ou** compromission du moteur de remédiation | Directeur de crise, RSSI, conformité, communication | G3 |
| **N3 — Crise majeure** | Service non rétabli à 2 h, **ou** perte du PC Hôte | Direction générale | G4 |

**Règle de l'automate :** l'automate ne tente **pas plus de 3 remédiations en 10 minutes** sur le même service. Au-delà, il s'arrête et passe en N1, pour éviter une boucle de redémarrages qui aggraverait l'arrêt.

## 4. Fiches scénarios

### Fiche S1 — Déni de service sur l'API de paiement (attaque A)

- **Risque EBIOS :** R1 (hacktiviste, ER1) · gravité G4 si non traité
- **Signaux :** latence et taux d'erreurs 5xx en forte hausse, débit anormal depuis une ou quelques sources, transactions en échec
- **Actions automatiques :**
  1. Limitation de débit pour la ou les sources identifiées (à construire : le WAF n'en a pas, et toute nouvelle règle le redémarre)
  2. Redémarrage propre de l'API si elle ne répond plus
  3. Vérification : transaction test réussie, latence revenue au niveau normal
- **Données :** aucune restauration, la base n'est pas touchée. Au 20/10, l'API du socle garde ses données en mémoire : le redémarrage (action 2) les efface
- **Objectif :** RTO ≤ 5 min (cible démonstrateur ≤ 60 s) · RPO = 0
- **Escalade :** N1 si l'attaque reprend depuis d'autres sources après la limitation
- **Retour à la normale :** limitation levée après 30 min sans trafic anormal, ou sur décision de l'opérateur
- **Risques résiduels :**

- L'attaquant change d'adresse : la limitation par source ne suffit plus (un vrai déni de service distribué exige une protection en amont, hors de portée du prototype)
- Un partenaire légitime au fort volume peut être limité à tort

### Fiche S2 — Injection applicative et altération de données (attaque B)

- **Risque EBIOS :** R2 (cybercriminel, ER2) · gravité G4
- **Signaux :** règle WAF déclenchée, motif anormal dans les journaux de l'API, erreurs applicatives, incohérence détectée dans les données
- **Actions automatiques :**
  1. Blocage de la source au WAF
  2. **Copie des journaux et de l'état de la base compromise** (preuves), avant toute restauration
  3. Restauration de la base depuis le dernier snapshot sain, puis rejeu des transactions légitimes (arbitrage en cours, voir `rto-rpo.md` §5)
  4. Rotation du secret concerné
  5. Vérification : transaction test réussie **et** contrôle d'intégrité des données
- **Objectif :** RTO ≤ 5 min (cible ≤ 3 min) · RPO = 0 transaction confirmée perdue
- **Escalade : N1 systématique**, même si la reprise réussit. Le RSSI qualifie l'incident ; la conformité évalue s'il est majeur au sens de DORA (une perte de données après un accès malveillant suffit)
- **Retour à la normale :** après correction de la vulnérabilité exploitée. D'ici là, la règle WAF reste active
- **Risques résiduels :**
  - La vulnérabilité est toujours dans le code : le WAF n'est qu'un pansement
  - Une porte dérobée a pu être déposée ; restaurer les données ne la supprime pas
  - Le snapshot « sain » peut contenir une altération plus ancienne, passée inaperçue
  - Après la rotation des secrets, les utilisateurs doivent se reconnecter

### Fiche S3 — Panne d'un service sans attaque

- **Couvre :** arrêt brutal d'un conteneur, saturation mémoire, base injoignable (testé par le chaos engineering, WOR-76)
- **Signaux :** contrôle de santé en échec, métriques absentes
- **Actions automatiques :** redémarrage du service ; si la base est en cause, vérification de son intégrité avant de relancer l'API
- **Objectif :** RTO ≤ 5 min · RPO = 0
- **Escalade :** N1 au-delà de 3 redémarrages en 10 minutes
- **Risques résiduels :** une cause profonde (disque plein, fuite mémoire) fera revenir la panne

### Fiche S4 — Remédiation déclenchée à tort (faux positif du modèle ML)

- **Risque :** non intentionnel, cité dans `ebios-rm.md`
- **Signaux :** remédiation exécutée sans anomalie confirmée par un second signal (SIEM, contrôle de santé)
- **Conduite à tenir :**
  1. Les actions de type S1 (limitation, redémarrage) restent autorisées : elles sont réversibles et courtes
  2. Les actions destructrices (restauration de la base, rotation des secrets) **exigent deux signaux concordants** (ML et WAF ou SIEM). Sinon, l'automate passe en N1

- **Risques résiduels :** une coupure courte provoquée par la défense elle-même ; elle est comptée dans le RTO

### Fiche S5 — Moteur de remédiation défaillant ou détourné

- **Risque EBIOS :** R3 (initié malveillant, ER6) · gravité G4
- **Signaux :** action hors du périmètre autorisé, appel au moteur depuis un composant non autorisé, rafale d'actions
- **Conduite à tenir :**
  1. Arrêter le moteur de remédiation
  2. Passer en **surveillance manuelle** : l'opérateur suit le tableau de bord et applique les fiches à la main
  3. Préserver les journaux du moteur
- **Escalade :** N2 immédiat
- **Prévention :** périmètre d'actions limité, authentification des appels, journalisation (WOR-64)
- **Risques résiduels :** pendant l'arrêt du moteur, plus aucune reprise automatique ; on retombe sur un RTO manuel de 30 min ou plus

### Fiche S6 — Suspicion de fuite de données

- **Risque EBIOS :** R5 (ER3) · gravité G3
- **Signaux :** volume de lecture anormal, requêtes inhabituelles sur la base, sortie de données vers une destination inconnue
- **Conduite à tenir :** couper l'accès de la source, préserver les preuves, **ne pas restaurer** (restaurer n'efface pas une fuite), prévenir le DPO
- **Escalade :** N2
- **Remarque :** non joué pendant la démo ; la fiche montre que la réponse diffère d'une simple remise en service (WOR-39)

### Fiche S7 — Perte du PC Hôte (PRA)

- **Risque EBIOS :** R7 (rançongiciel) ou panne matérielle · gravité G4
- **Conduite à tenir :**
  1. Préparer une machine de remplacement (prérequis du README, WOR-49)
  2. Cloner le dépôt Git, redéployer avec Docker Compose et les playbooks Ansible
  3. Régénérer les secrets : Vault tourne sur le PC Hôte, son contenu est perdu avec lui. Le déploiement en crée de nouveaux quand `infra/.env` est absent
  4. Restaurer la dernière sauvegarde de la base, **si elle existe hors de l'hôte**
- **Objectif :** aucun objectif chiffré tenable avec un seul hôte
- **Risques résiduels : perte de toutes les données depuis la dernière copie hors hôte**. C'est le principal écart du démonstrateur (voir §8)

## 5. Mode dégradé

Quand la reprise automatique échoue, on maintient ce qui peut l'être :

| Service | En mode dégradé | Interdit |
|---|---|---|
| Paiement | Limitation de débit stricte : on accepte moins de transactions plutôt qu'aucune | — |

| Service | En mode dégradé | Interdit |
|---|---|---|
| WAF | Mode de filtrage strict | **Le contourner** pour rétablir le trafic plus vite |
| Consultation | Lecture seule, voire suspendue pour soulager la base | — |
| Supervision | Surveillance manuelle sur le tableau de bord | — |
| Assistant RAG | Peut être arrêté pour libérer des ressources | Lui donner des droits d'action (WOR-57) |

## 6. Choix de restauration

| Élément | Où se trouve la référence saine | Comment on restaure | Fréquence | Responsable |
|---|---|---|---|---|
| Code et configuration des services | Dépôt Git, version taguée (WOR-80) | Redéploiement Docker Compose et Ansible | À chaque livraison | Reza |
| Règles du WAF | Dépôt Git | Redémarrage du WAF (pas de rechargement à chaud) | À chaque modification | Axel |
| Secrets | HashiCorp Vault, sur le PC Hôte | Rotation puis redémarrage des services concernés | Après tout incident d'intégrité | Axel |
| Base de données | **Aucune sauvegarde au 20/10.** Cible : snapshot + journal des transactions (`rto-rpo.md` §5) | Restauration du snapshot puis rejeu | Minimum : un `pg_dump` avant chaque essai | Reza, Michael |
| Journaux | Loki, rétention 7 jours, sur le PC Hôte | **Jamais écrasés** ; copiés avant toute restauration avec `scripts/export-logs.sh`. Au 20/10, la remise à l'état sain n'appelle pas cet export : il faut le lancer à la main | En continu | Axel |
| Modèle ML | Dépôt Git (`ml/`) | Rechargement de la version validée | À chaque entraînement | Léa |
| Index du RAG | Documents du dépôt | Réindexation | À chaque mise à jour des documents | Léa |

> ***Ne pas confondre restauration et remise à l'état sain.*** *La remise à l'état sain (`scripts/reset-known-good.sh`, WOR-90) supprime les volumes pour rejouer un essai : elle efface les transactions,* ***mais aussi les journaux Loki et les métriques Prometheus****, donc les preuves. Elle ne doit* ***jamais*** *servir à reprendre après un incident réel.*

## 7. Communication et notification

| Destinataire | Quand | Quoi | Qui |
|---|---|---|---|
| Opérateur d'astreinte | Dès N0 | Alerte et état de la reprise sur le tableau de bord | Automate |
| Partenaires commerçants | Dès N1 si leurs transactions échouent | Nature de la gêne, heure de reprise estimée | Communication |

| Destinataire | Quand | Quoi | Qui |
|---|---|---|---|
| ACPR, incident majeur au sens de DORA | Notification initiale dans les 4 h après la classification en majeur (et au plus tard 24 h après la détection), rapport intermédiaire sous 72 h après la notification initiale, rapport final sous 1 mois après le dernier rapport intermédiaire | Formulaire réglementaire, à partir des journaux du SIEM | Conformité |
| CNIL | Sous 72 h en cas de violation de données personnelles | Notification RGPD | DPO |

Délais DORA : règlement délégué (UE) 2025/301. L'assistant RAG peut préparer un brouillon de notification à partir des journaux ; un humain le valide et l'envoie.

## 8. Risques résiduels après la reprise

| Risque résiduel | Pourquoi il subsiste | Traitement proposé |
|---|---|---|
| L'attaquant revient, depuis une autre source | La limitation est faite par source, sur un seul hôte | Protection anti-déni de service en amont (contexte industriel) |
| Vulnérabilité toujours présente après une injection | Le WAF bloque, mais le code n'est pas corrigé | Correctif et test de non-régression avant de lever le niveau N1 |
| Porte dérobée ou altération ancienne | Restaurer les données ne nettoie pas tout | Analyse après incident à partir des journaux conservés |
| Hôte unique | Point de défaillance unique | Deuxième site et sauvegardes hors site (`nis2-dora.md` §4) |
| Sauvegardes sur le même hôte | Perdues avec l'hôte | Copie hors site, immuable |
| Boucle de remédiation | Un incident persistant peut faire redémarrer un service en boucle | Limite de 3 remédiations en 10 minutes, puis escalade |
| Faux positifs ML | Un modèle entraîné sur peu de données | Deux signaux exigés pour les actions destructrices ; réentraînement |
| Droits élevés du moteur de remédiation | Nécessaires pour agir sur les conteneurs | Périmètre limité, authentification, journalisation (WOR-64) |

## 9. Tests et maintien du plan

| Test | Ticket | Scénarios vérifiés | Résultat |
|---|---|---|---|
| Premiers tests de restauration | WOR-75 | S2, S7 (en partie) | À remplir |
| Chaos engineering | WOR-76 | S3, S4 | À remplir |
| Démo complète répétée 3 fois | WOR-78 | S1, S2 | À remplir, temps dans `rto-rpo.md` §6 |

Le plan est mis à jour après chaque test et après chaque incident (retour d'expérience, DORA art. 13).

## 10. Décisions en attente

1. Méthode de restauration de la base après une injection (snapshot seul, ou snapshot et rejeu) : Michael, Reza.
2. Fréquence des snapshots de la base : Reza.
3. Règle des deux signaux pour les actions destructrices et limite de 3 remédiations : à intégrer au moteur (WOR-38) si l'équipe valide.